

CCAF Reviewer Overview

Version 1.3.1 | Synthetic Reference Prototype | Stable snapshot: review-v1.3.1

What CCAF is

The **Continuous Control Assurance Framework (CCAF)** is a documented methodology and open-source reference implementation for applying repeatable analytics to authorized data extracts. It helps audit, risk, and cybersecurity teams expand beyond periodic sampling by testing every eligible record in the supplied in-scope extract and organizing reported conditions for professional follow-up.

CCAF does not establish that a source extract is complete, determine control effectiveness, or make remediation decisions. It applies transparent procedures consistently and preserves the evidence needed to understand and reproduce the run.

How it works

Authorized extracts > Source checks > 20 procedures > Exceptions + evidence > Professional review

What it tests

Module	Tests	Focus	Example condition reported for review
Privileged Access	7	Access status, approval, conflicts, dormancy, activity, and expiry	Terminated user retains active privileged access
Change Management and Logging	7	Approval, separation, emergency review, deployment, logs, and testing	Production deployment lacks a valid change record
Reconciliation and Payments	6	Settlement, tolerance, identifiers, aging, activity, and threshold patterns	Due ledger item lacks a processor-settlement record

What the fixed demonstration establishes

Module	Planted	Reported
Privileged Access	39	39
Change Management and Logging	49	49
Reconciliation and Payments	77	77
Total	165	165

The official seed-42 run also reported **3 additional peer-comparison observations**, producing **168 total exceptions**. This is regression evidence for the fixed synthetic scenario, not a production detection rate, external validation, or evidence of adoption.

Interpretation boundaries

- Synthetic demonstration data only; no employer, client, or production information is included.
- "Every eligible record" refers only to the supplied in-scope extract, not an institution's unverified full population.
- A reported exception is a condition for investigation, not a confirmed control deviation or deficiency.
- The bounded 20-test reference set complements rather than replaces enterprise security, GRC, audit, or monitoring platforms.
- No institutional adoption, regulatory approval, certification, external validation, or production performance is claimed.

For the reviewer

A document-based design review of the methodology and control-test catalog is sufficient. Repository inspection and local reproduction are optional. The response should identify the materials and procedures personally examined and reflect the reviewer's independent professional judgment.

CCAF Control-Test Quick Reference

20 detective procedures | Three modules | Version 1.3.1

ID	Procedure focus	Example condition reported for review
PA-01	Active privileged access after termination	Terminated user retains an active privileged grant
PA-02	Recorded approval before access activation	Active grant has no recorded approver
PA-03	Separation of grantee and approver	User approved the user's own access
PA-04	Dormant privileged access	No successful authentication within the approved dormancy period
PA-05	Incompatible entitlements	User holds an institution-defined conflicting entitlement pair
PA-06	Unusual after-hours privileged activity	Activity exceeds the approved peer-comparison threshold
PA-07	Expired temporary privileged access	Grant remains active after approved expiry and grace period
CM-01	Approval for implemented production changes	Implemented change lacks recorded approval
CM-02	Separation of approval and implementation	Same identifier approved and implemented a change
CM-03	Review of emergency changes	Emergency change lacks post-implementation review
CM-04	Deployment linked to a valid change	Production deployment lacks a valid change reference
CM-05	Timely reporting by required log sources	Source exceeds the approved heartbeat interval
CM-06	Emergency-change rate against baseline	Recent rate meets the configured increase threshold
CM-07	Preproduction testing and approval	Change lacks testing or test-approval evidence
TR-01	Ledger-to-processor settlement matching	Due ledger item lacks a processor-settlement record
TR-02	Amount consistency within tolerance	Matched amounts differ beyond approved tolerance
TR-03	Transaction-identifier uniqueness	Identifier appears in more than one ledger row
TR-04	Aging of unreconciled items	Open item exceeds the approved aging period
TR-05	Unusual transaction velocity	Activity exceeds the approved peer-comparison threshold
TR-06	Activity below an approval limit	Account meets the configured threshold-hovering pattern
Completed	Required records and analytical conditions were present; the result applies only to the reported eligible population.	
Not Evaluable	A required condition was absent; no clean result or exception rate is implied.	
Tailoring	Source mappings, thresholds, calendars, policies, peer groups, conflict matrices, roles, and escalation requirements must be authorized and validated locally.	
Evidence	Retain approved configuration, source queries or reports, source-assurance and data-quality records, status, eligible population, exceptions, rule version, input hashes, disposition, and supporting records.	
An automated exception begins professional investigation. It does not by itself establish a control deviation, deficiency, misconduct, compliance failure, or financial loss.		